

EDY SOC Analytics

Camada analítica profissional para operações de segurança



Edmilson Gomes
Power BI • Engenharia de Dados • Blue Team
24 de agosto de 2026

Autor: Edmilson Gomes

Data: 24 de agosto de 2026

Área: Power BI, Engenharia de Dados e Segurança da Informação

Resumo

O EDY SOC Analytics é uma solução analítica em Power BI que demonstra como eventos, alertas e incidentes de um Centro de Operações de Segurança podem ser transformados em informação decisória. O projeto usa PBIP/PBIR/TMDL, dados sintéticos determinísticos, Power Query, modelo estrela, 41 medidas DAX, RLS, acessibilidade, layout mobile, interações e testes automatizados. A integração conceitual com EDY Shield, EDY Sentinel, EDY SIEM e EDY RECON não acessa bancos, logs ou credenciais desses produtos.

Palavras-chave: Power BI; SOC; Blue Team; DAX; Power Query; MITRE ATT&CK; RLS; PL-300.

1. Problema e justificativa

Um SOC recebe telemetria em escala e precisa responder rapidamente: quais incidentes estão ativos, quais são críticos, onde o backlog cresce, quais ativos concentram risco, quais regras produzem falsos positivos e quanto tempo a equipe leva para detectar, reconhecer, triar, conter e resolver. Relatórios centrados apenas em volume podem esconder ruído, atrasos e falhas de cobertura.

O projeto preserva a sequência evento → alerta → incidente → resposta. Sua relevância acadêmica está na integração de preparação de dados, modelagem, análise, visualização e segurança, competências relacionadas à PL-300. Sua relevância profissional está na demonstração de decisões auditáveis e segurança por design.

2. Objetivos

O objetivo geral foi construir um relatório funcional, reproduzível e seguro para apresentar o estado do SOC e apoiar priorização. Os objetivos específicos foram:

- gerar dados sintéticos coerentes e reproduzíveis;
- implementar limpeza real no Power Query;
- modelar fatos, dimensões e pontes em estrela;
- definir métricas com relógios operacionais separados;
- criar dez páginas com narrativa executiva e operacional;
- validar drillthrough, filtros, bookmarks, RLS, mobile e acessibilidade;
- documentar contrato futuro com o ecossistema EDY;
- medir desempenho e automatizar testes seguros.

3. Metodologia e pesquisa

O trabalho foi dividido em pesquisa, contrato, geração de dados, ETL, modelagem, DAX, design, validação e documentação. As fontes primárias incluíram Microsoft Learn para Power BI/PL-300, PBIP/PBIR/TMDL, star schema, acessibilidade, mobile, RLS e desempenho; MITRE ATT&CK Enterprise para táticas/técnicas; NIST CSF 2.0 e NIST SP 800-61 Rev. 3 para governança e resposta a incidentes.

Cada fase possui checkpoints com estados PLANEJADO, IMPLEMENTADO, VALIDADO ou BLOQUEADO. Um artefato só foi marcado validado após teste real. A estrutura do relatório foi verificada pela CLI oficial

Microsoft e renderizada no Power BI Desktop.

4. Ética, privacidade e segurança

O projeto não acessou dados operacionais. O gerador produz nomes, ativos, regras, fontes e identificadores fictícios. Endereços de rede pertencem a faixas documentais; comentários de incidentes são seguros e não operacionais. O manifesto classifica os registros como `SYNTHETIC_DEMO_DATA`.

As integrações EDY são contratuais. Um JSON Schema define campos e restrições para uma futura exportação do EDY SIEM, acompanhado de amostras válidas/inválidas e testes. Nenhuma modificação foi feita nos demais projetos EDY.

5. Geração e qualidade dos dados

O gerador Python utiliza seed fixa e cobre 18 meses. Foram produzidos 120.000 eventos, 18.000 alertas, 3.200 incidentes, 18.034 registros de lifecycle e 4.000 vínculos incidente-técnica. Sazonalidade, picos controlados, criticidade rara, diferenças entre fontes, regras ruidosas, backlog, SLA, nulls e duplicidades permitem exercitar limpeza e análise.

As camadas `raw`, `reference` e `expected` separam entrada deliberadamente imperfeita, referências controladas e oracle de validação. O manifesto registra contagens, seed, período e hashes. Testes verificam determinismo, tipos, chaves, integridade referencial, lifecycle, SLA, MITRE e ausência de PII/segregados.

6. Power Query

O Power Query executa conexão parametrizada, tipagem, padronização de severidade/status, timestamps, tratamento de null, deduplicação e criação de chaves. Eventos sem ativo recuperável são preservados pelo membro desconhecido `AssetKey = 0`; analistas ausentes usam `AnalystKey = 0`. Registros realmente inválidos são separados em `DQ_RejectedRows`.

O parâmetro `pProjectRoot` torna o PBIP portátil. Funções e staging são separados das tabelas carregadas. A configuração de privacidade que ignora níveis está restrita ao arquivo e é aceitável somente enquanto todas as fontes forem CSVs sintéticos locais da mesma origem.

7. Modelo dimensional

O modelo possui 21 tabelas. Os fatos representam evento, alerta, incidente, lifecycle e SLA. As dimensões conformadas incluem data, hora, ativo, produto-fonte, severidade, status, regra, tática, técnica, analista, classificação e SLA. A ponte incidente-técnica resolve a relação many-to-many do MITRE.

Filtros são unidirecionais por padrão. A ponte MITRE usa propagação bidirecional controlada para que táticas e técnicas filtrem medidas de incidentes sem criar um segundo caminho ambíguo. Chaves substitutas são determinísticas e derivadas dos IDs sintéticos, não da ordem física dos CSVs.

8. DAX e KPIs

As 41 medidas incluem eventos, alertas, incidentes, novos/ativos/fechados, criticidade, backlog, aging, fechamento, escalonamento, reabertura, falsos positivos, conversão, SLA, violações, MTTD, MTTA, triagem, contenção, resolução, recuperação, tendência, período anterior, cobertura MITRE, risco de ativos, ruído de regras e produtividade contextualizada.

Os relógios foram separados: MTTD mede evento até detecção; MTTA, criação até reconhecimento; triagem, contenção, resolução e recuperação possuem métricas próprias. Neste projeto, MTTR significa tempo até resolução. Medidas derivadas usam bases reutilizáveis, VAR, DIVIDE e contextos explícitos.

9. Relatório e design Signal Grid

A identidade Signal Grid utiliza dark graphite, superfícies discretas, ciano técnico e cores semânticas moderadas. O relatório usa somente visuais nativos, evitando dependências externas. A composição prioriza densidade controlada, alinhamento e leitura.

As dez páginas são Command Center, SOC Operations, Incident Lifecycle, Threat & MITRE, Assets & Exposure, Detection Engineering, Analyst & SLA, Data Quality, Incident Drillthrough e Methodology. A narrativa começa por prioridade e tendência, aprofunda operação/ameaça/exposição e termina em detalhe e transparência metodológica.

10. Interações e validação

Foram implementados navegadores de página, slicers, seleção cruzada, drillthrough, ações, bookmark e reset. Uma seleção de severidade crítica alterou incidentes ativos de 253 para 7; limpar restaurou 253. O drillthrough abriu um incidente com timeline e MITRE. O bookmark restaurou alertas de 2 mil para 18 mil após uma seleção. A navegação por teclado abriu Methodology.

O PBIR contém 101 visuais nativos e 91 estados mobile. A CLI oficial validou o relatório com zero erros e zero avisos. O modelo em memória aprovou 13 asserts, confirmando contagens, membros desconhecidos, rejeitados e filtro MITRE.

11. Acessibilidade e mobile

Os visuais possuem alt text, títulos descritivos e ordem de tabulação. Severidade também é expressa textualmente e gráficos relevantes têm alternativa tabular. Botões foram testados por foco e teclado. Dez layouts mobile foram configurados no editor móvel; navegadores horizontais foram omitidos e a tipografia dos cartões foi ajustada até eliminar truncamento.

12. RLS

Dois papéis foram implementados. SOC_Manager possui visão integral e foi validado com 3.200 incidentes. SOC_Analyst usa filtro dinâmico e, sem identidade correspondente, retornou zero linhas, demonstrando deny-by-default. A simulação de uma identidade fictícia específica pelo campo Outro usuário não foi concluída de modo confiável e permanece registrada como limitação.

13. Desempenho

Cinco consultas DAX representativas foram executadas com cinco repetições aquecidas. O maior p95 da execução final foi 8,16 ms, abaixo do orçamento interno de 2.000 ms. A captura de dez páginas, incluindo navegação, settle e PNG, levou 17.400,69 ms, média de 1.740,07 ms/página. Os resultados são locais e variam conforme host, versão e cache.

14. Resultados

O projeto demonstrou que um conjunto sintético pode sustentar uma solução Power BI completa sem expor operações reais. A separação de relógios reduziu ambiguidade; o modelo estrela permitiu filtros coerentes; a ponte MITRE propagou contexto de técnica; os testes detectaram erros reais de chave e relacionamento antes da entrega. A identidade visual tornou o relatório consistente em desktop e mobile.

15. Limitações e trabalhos futuros

Os dados não estimam risco real. A publicação em Power BI Service e a atribuição de papéis RLS dependem de workspace autorizado. Tempos medidos não são SLAs. Trabalhos futuros: ingestão contratual do EDY SIEM, atualização incremental, monitoramento de qualidade, validação com tecnologia assistiva e comparação com metas operacionais aprovadas.

Referências

- MICROSOFT. PL-300: Microsoft Power BI Data Analyst - Study guide. Microsoft Learn, 2026.
- MICROSOFT. Understand star schema and the importance for Power BI. Microsoft Learn.
- MICROSOFT. Power BI Desktop projects (PBIP). Microsoft Learn.
- MICROSOFT. Design Power BI reports for accessibility. Microsoft Learn.
- MICROSOFT. Create mobile-optimized Power BI reports. Microsoft Learn.
- MICROSOFT. Row-level security with Power BI. Microsoft Learn.
- MITRE. ATT&CK Enterprise Matrix. MITRE ATT&CK.
- NIST. Cybersecurity Framework 2.0. 2024.
- NIST. SP 800-61 Rev. 3. 2025.

Anexo visual

Resumo das dez páginas renderizadas no Power BI Desktop.

